

SECURING INFORMATION SYSTEMS

Introduction

Security: refers to the **policies, procedures, and technical measures** used to prevent **unauthorized access**, alteration, theft, or physical damage to **Information Systems**

Control: are **methods, policies, and organizational procedures** that ensure the **safety of the organization's assets**; the **accuracy and reliability** of its records; and **operational** adherence to management standards.

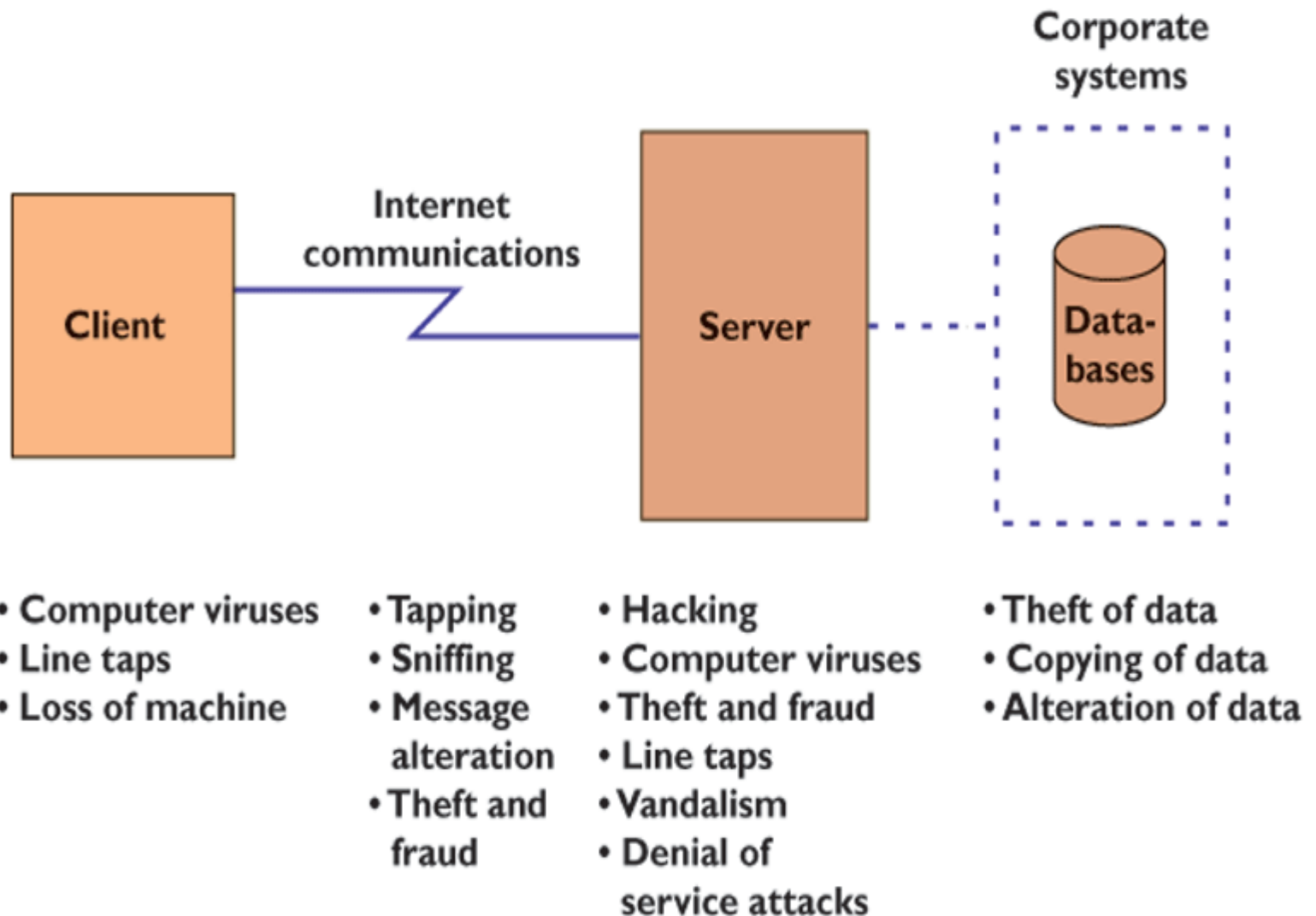
Vulnerability

- A vulnerability is a **weakness** within the system that can potentially lead to **loss or harm**.
- The threat of **natural disasters** has instances that can make the system vulnerable.
- If a system has programmes that have **threats** (erroneous programmes) then the system is vulnerable.

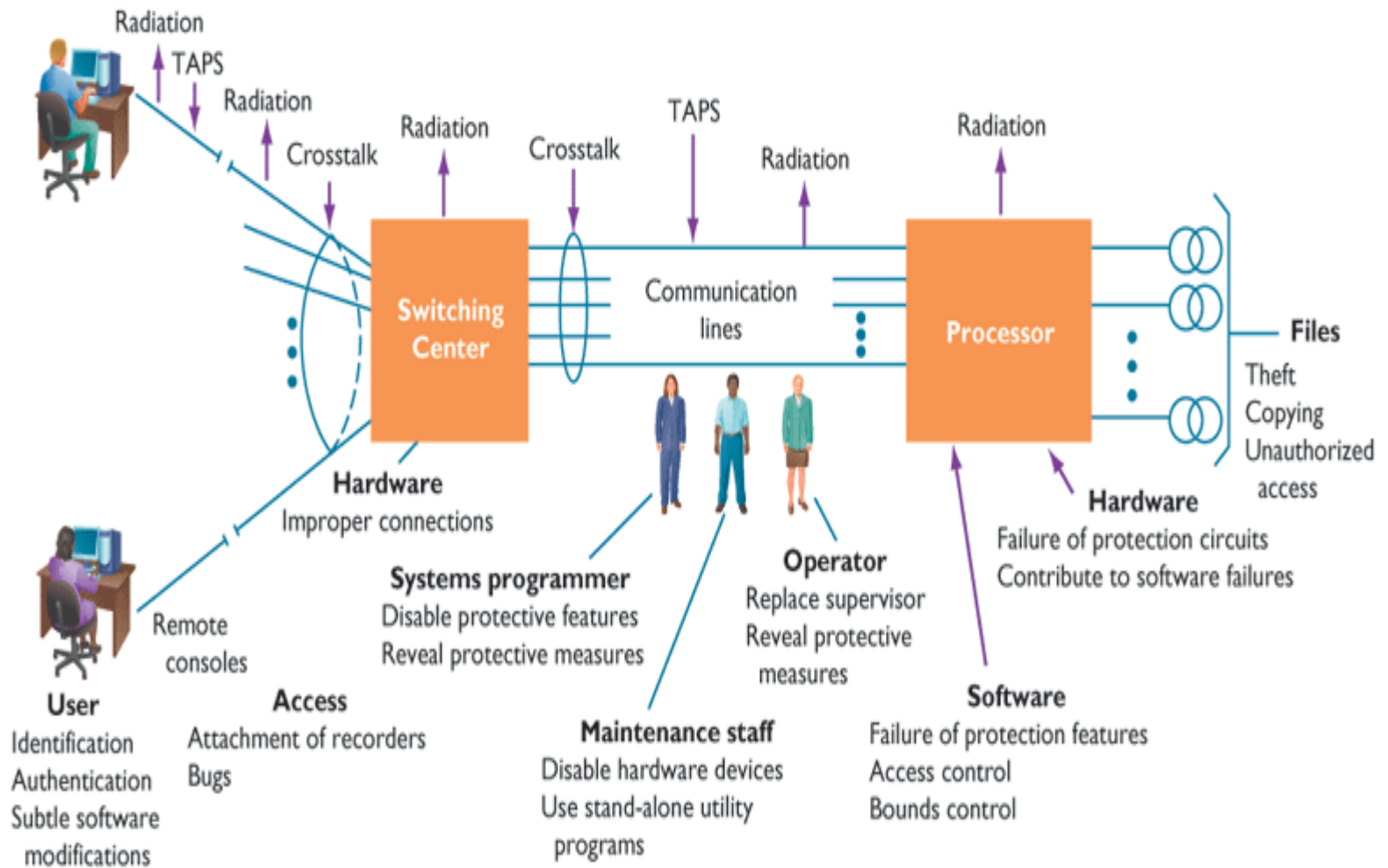
Threats to Computerized Information Systems

- Hardware failure
- Software failure
- Personnel actions
- Terminal access penetration
- Theft of data, services, equipment
- Fire
- Electrical problems
- User errors
- Unauthorized program changes
- Telecommunication problems

Internet security challenges and vulnerabilities



Telecommunications networks vulnerabilities



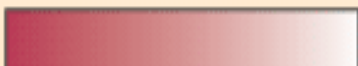
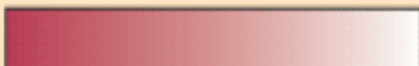
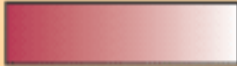
Computer Crime

- Defined by the U.S. Department of Justice as “**any violations of criminal law that involve a knowledge of computer technology for their perpetration, investigation, or prosecution.**”
- Computer crime includes:
 - Unauthorized use, access, modification, or destruction of hardware, software, data, or network resources.
 - The unauthorized release of information.
 - The unauthorized copying of software.
 - Denying an end user access to his/her own hardware, software, data, or network resources.
 - Using or conspiring to use computer or network resources illegally to obtain information or tangible property

Cont'ed

- Breaching the confidentiality of protected computerized data.
- Knowingly accessing a protected computer to commit fraud.
- Threatening to cause damage to a protected computer.
- Intentionally accessing a protected computer and causing damage or deliberately.
- Sabotage

Cybercrime Protection Measures

Security Technologies Used	Security Management
Antivirus 96% 	■ Security is about 6 to 8% of the IT budget in developed countries.
Virtual private networks 86% 	■ 63% currently have or plan to establish in the next two years the position of chief security officer or chief information security officer.
Intrusion-detection systems 85% 	■ 40% have a chief privacy officer, and another 6% intend to appoint one within the next two years.
Content filtering/monitoring 77% 	■ 39% acknowledged that their systems had been compromised in some way within the past year.
Public-key infrastructure 45% 	■ 24% have cyber risk insurance, and another 5% intend to acquire such coverage.
Smart cards 43% 	
Biometrics 19% 	

MALICIOUS SOFTWARE

- **Malicious software** programs are referred to as **malware** and include a variety of threats, such as **computer viruses, worms** and **Trojan horse**.
- **Computer virus** is a software program that attaches itself to other software programs or data files in order to be executed, usually without user knowledge or permission.
- **Worms** are independent computer programs that **copy themselves** from one computer to other computers over a network.
- **Trojan horse** is a software program that does something other than **expected**.(tricks)

Hackers

- A **hacker** is an individual who intends to gain **unauthorized access** to a computer system.

Spoofing and sniffing

Hacker attempting to hide their **true identities** often spoof or misrepresent themselves by using fake e-mail addresses or masquerading as someone else.

Spoofing also may involve **redirecting** a web link to an address different from the intended one.

Spoofing ;faking an e-mail address or Web page to trick users into passing along critical information like passwords or credit card numbers.

Sniffer: is a type of eavesdropping program that **monitors information** travelling over a **network**.

Sniffers enable hackers to steal proprietary information from anywhere on a network, including e-mail **messages**, company files and **confidential** reports.

Denial-of-Service Attacks

- Hackers flood a network server or web server with many thousands of **false communications** or requests for services to **crash the network**.
- The network receives so **many queries** that it cannot keep up with them and is thus **unavailable** to service legitimate requests.

i.e. hammering a website's equipment with too many requests for information.

- Clogging the system, slowing performance, or crashing the site.

Computer Forensics

- **Computer Forensics** is the scientific collection, examination, authentication, preservation, and analysis of data held on or retrieved from computer storage media in such a way that the information can be used as evidence in a **court of law**.
- It deals with the following:
 - Recovering data from computers while preserving evidential integrity.
 - Securely storing and handling recovered electronic data.
 - Presenting the information to a court of law

Information System Controls

- IS controls are both manual and automated and consist of both **general** controls and **application** controls.
- **General Controls** govern the **design, security, use of computer programs** and the security of data files in general throughout the organization's information technology infrastructure.
- Apply to all computerized applications.
- Consist of combination of hardware, software, and manual procedures that create an overall control environment.

Cont'ed

- General controls include:
 - software control,
 - physical hardware controls,
 - computer operations controls,
 - data security controls,
 - controls over implementation of system processes,
 - administrative controls.

Application Controls

- Are **specific controls** unique to each computerized application, such as payroll or order processing.
- They include both **automated and manual** procedures that ensure only **authorized data** are completely and accurately processed by that application.
- Application controls can be classified as (1) input controls, (2) processing controls, and (3) output controls.

Cont'ed

- **Input controls** check data for accuracy and completeness when they enter the system
- **Processing controls** establish that data are complete and accurate during updating.
- **Output controls** ensure that the results of computer processing are accurate, complete, and properly distributed.

Protecting the Digital Firm

- High-availability computing
- Fault-tolerant computer systems
- Disaster recovery planning
- Business continuity planning
- Load balancing; mirroring; clustering
- Recovery-oriented computing
- Managed security service providers (MSSPs)

Disaster recovery planning and Business continuity planning

- **Disaster recovery planning** devices plans for the **restoration of computing and communications** services after they have **been disrupted**.
- It focus on the technical issues involved in keeping systems up and running, such as **file back up**.
- **Business continuity planning**; focuses on how the company can **restore business operations** after a **disaster strikes**.
- Identifies critical business processes and determines action plans for handling mission-critical functions if systems go down.

Role of Auditing

MIS Audit

- Identifies all controls that govern individual information systems and assesses their effectiveness.
- Lists and ranks all control weaknesses and estimates the probability of their occurrence.

Technologies and tools for protecting information resources

- **Access control** consists of all the **policies and procedures** a company uses to prevent improper access to systems by unauthorized insiders and outsiders. To gain access a user must be **authorized and authenticated**.
- **Authentication** refers to the ability to know that a **person is who he or she claims to be**.
- Access control software is designed to allow only authorized users to use systems or to access data using some method for authentication.

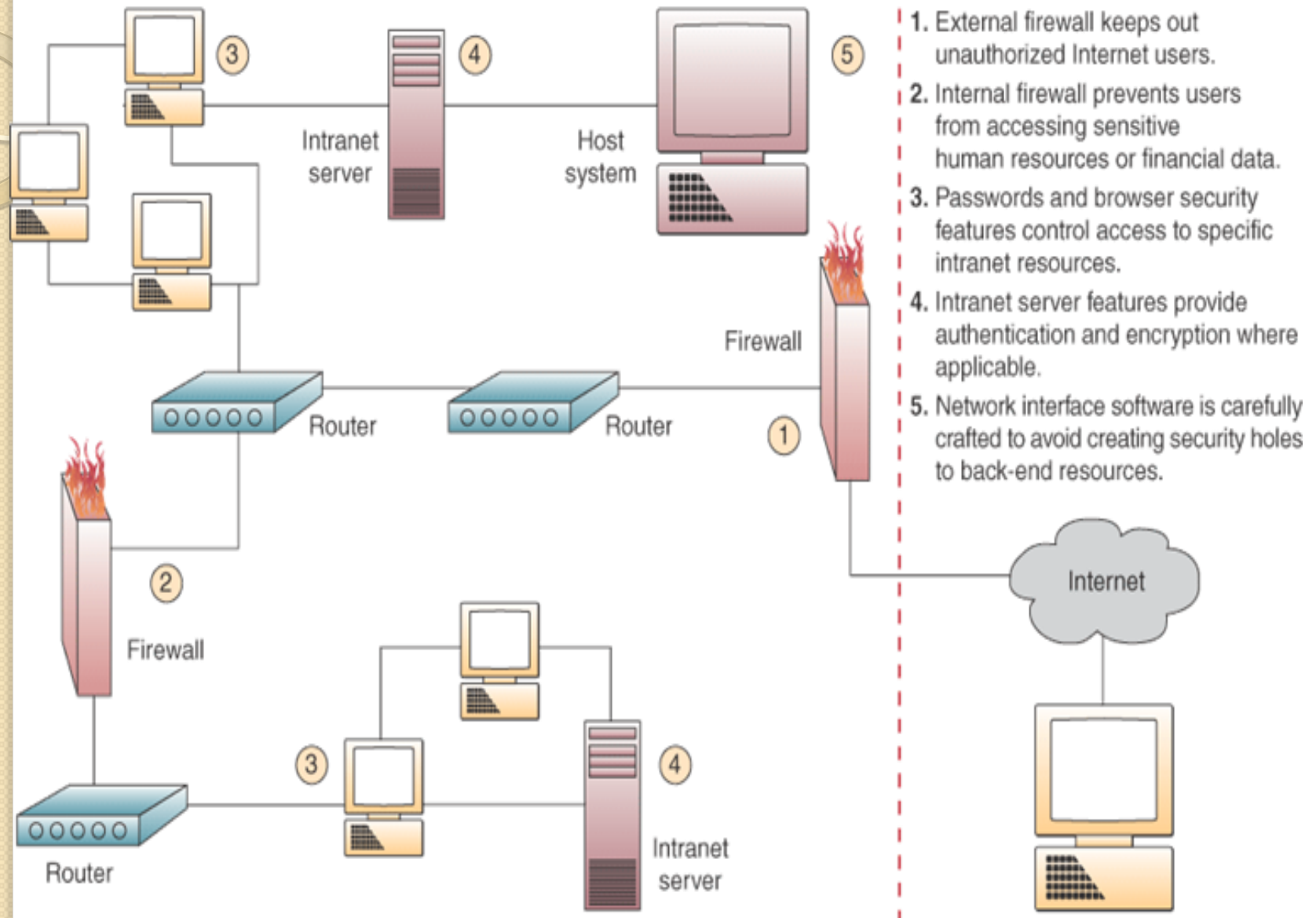
Biometric Authentication

- **Biometric Authentication**; uses systems that **read and interpret individual human traits**, such as fingerprints, irises, and voices, in order to grant or deny access.
- Is based on the measurement of a **physical or behavioral** trait that makes **each individual unique**.
- It compares a person's unique characteristics, such as the fingerprints, face or retinal image, against a stored profile of these characteristics to determine **whether there are any differences** between these characteristics and the stored profile.

Firewalls

- A **firewall** is a combination of hardware and software that **controls the flow of incoming and outgoing network traffic**.
- It is generally placed between the organization's **private internal networks** and **distrusted external networks**, such as the internet, although firewalls can also be used to protect one part of a company's network from the rest of the network.
- There are a number of firewall screening technologies: **static packet filtering, stateful inspection, network address translation, and application proxy filtering**.

Internet and Intranet Firewalls



Intrusion Detection systems

- **Intrusion Detection systems** feature full-time monitoring tools placed at the most vulnerable points or “**hot spots**” of corporate networks to **detect and deter intruders continually**.
- The system generates an alarm if it finds a **suspicious or anomalous event**.
- Monitoring software examines events as they are happening to discover security attacks in progress.
- The intrusion detection tool can also be customized to shut down a particularly sensitive part of a network if it receives unauthorized traffic.

Antivirus and Antispyware Software

- Antivirus software is designed to check computer systems and drives for the presence of **computer viruses**.
- Leading antivirus software vendors such as McAfee, Symantec, Avira

Encryption

- **Encryption** is the **process of converting a plaintext** message into a **secure coded form** of text called **cipher** text that cannot be understood without converting back via decryption (the reverse process) to plaintext again.
- This is done via a mathematical function and a special encryption/decryption password called the key.

Encryption is generally used to:

- ◆ Protect data in transit over networks from unauthorized interception and manipulation.
- ◆ Protect information stored on computers from unauthorized viewing and manipulation
- ◆ Deter and detect accidental or intentional alterations of data
- ◆ Verify authenticity of a transaction or document

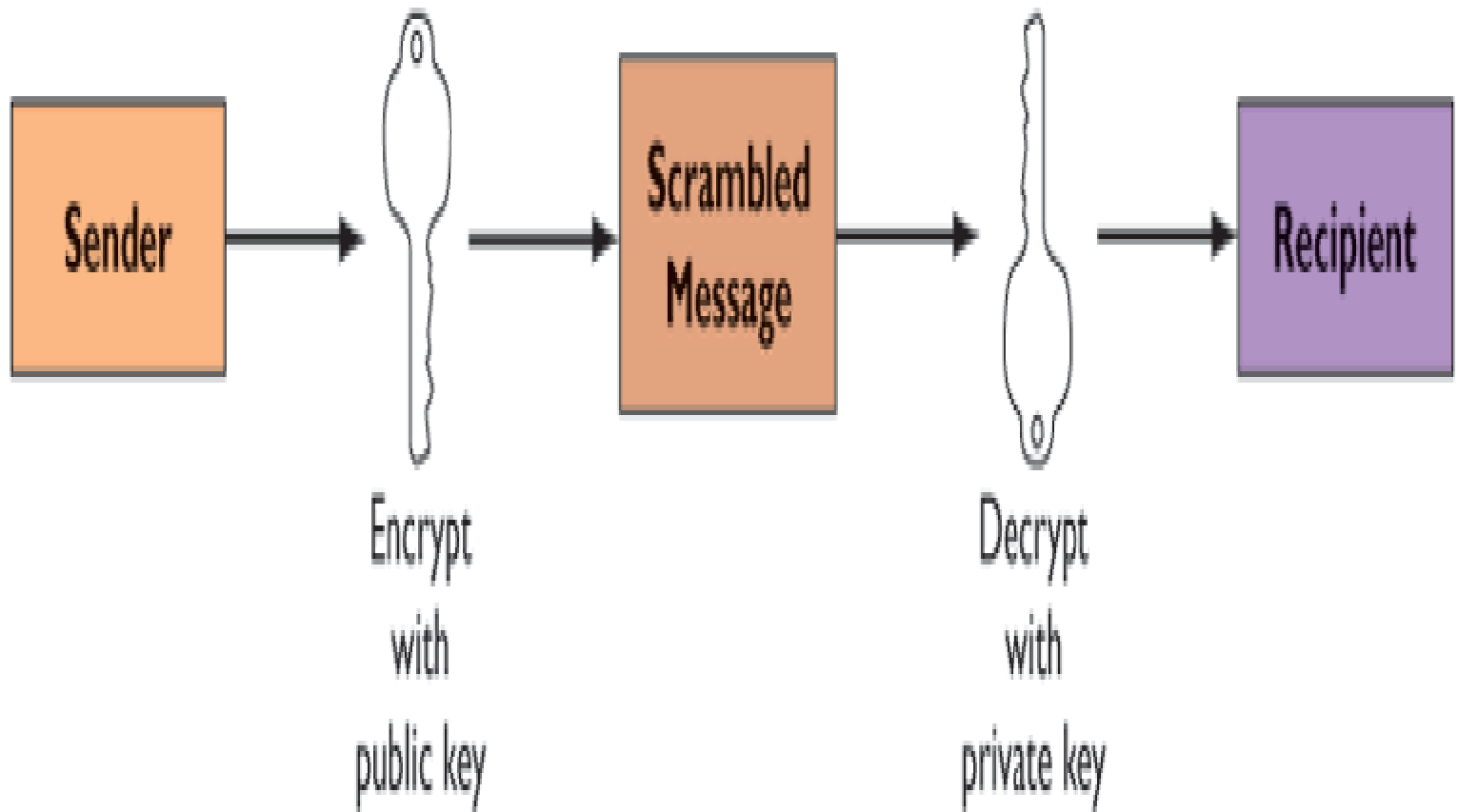
Cont'ed

- There are two alternative methods of encryption: **symmetric key encryption** and **public key encryption**.
- In **symmetric key encryption**, the sender and receiver establish a secure internet session by creating a **single encryption key** and sending it to the receiver so both the sender and receiver share the same key.
- **Public key encryption**, uses two keys: one shared(or public) and one totally private

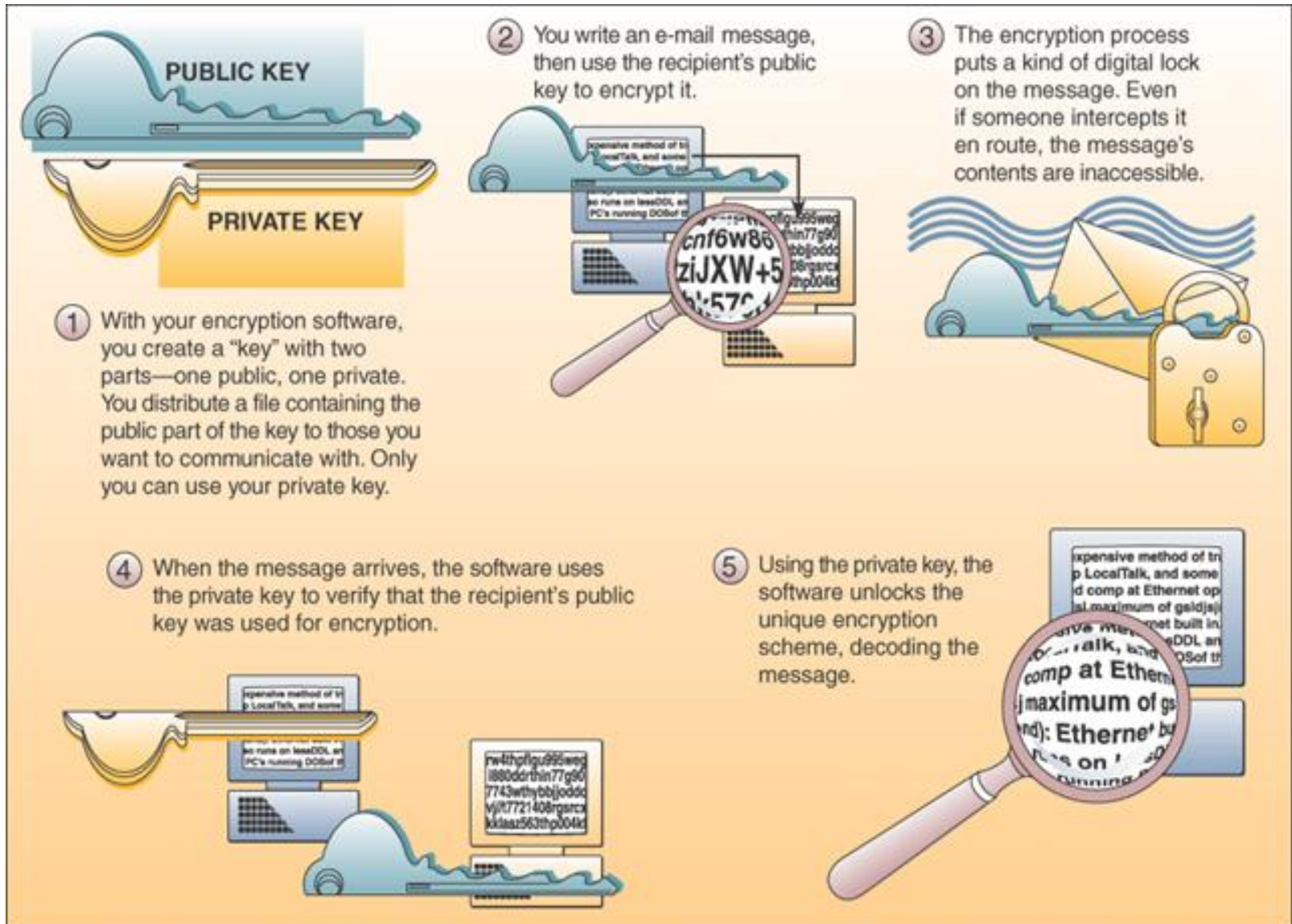
Public key encryption

- The keys are mathematically related so that data encrypted with one key can be decrypted using only the other key.
- To send and receive messages, communicators first **create separate pairs of private and public keys**.
- The public key is kept in a **directory** and the private key must be kept **secret**.
- The sender encrypts a message with the recipient's **public key**.
- On receiving the message, the recipient uses his or her **private key** to decrypt it.

Public key encryption



Public/Private Key Encryption



Security Measures

- Security Codes
 - Multilevel password system
 - Encrypted passwords
 - Smart cards with microprocessors
- Backup Files
 - Duplicate files of data or programs
- Security Monitors
 - Monitor the use of computers and networks
 - Protects them from unauthorized use, fraud, and destruction

Security Measures

- Biometrics
 - Computer devices measure physical traits that make each individual unique
 - Voice recognition, fingerprints, retina scan
- Computer Failure Controls
 - Prevents computer failures or minimizes its effects
 - Preventive maintenance
 - Arrange backups with a disaster recovery organization
- A disaster recovery plan contains formalized procedures to follow in the event of a disaster

Confidentiality, Integrity and Availability

- To retain a competitive advantage and to meet basic business requirements organizations must endeavour to achieve the following security goals:
- **Confidentiality** – protect value of information and preserve the confidentiality of sensitive data.
- **Integrity** – ensure the accuracy and reliability of the information stored on the computer systems.
- **Availability** – ensure the continued access to the information system and all its assets to legitimate users